

Correspondência ISO/IEC 27701 e LGPD

A PONTE QUE NÃO EXISTE EM ANEXO OFICIAL · MAPA DE PARTIDA, NÃO EQUIVALÊNCIA

Da Norma à Liderança
O método do Empilhamento ·
Instrumento 16
André Augusto Azarias de Souza

Não existe anexo oficial da 27701 para a LGPD, e é exatamente essa ponte que um programa brasileiro precisa montar sozinho. A tabela é a **correlação interpretativa do autor**, sobre a edição de 2019 da norma e na data de corte da 1ª edição do livro: confira cláusulas e redações vigentes antes de citá-la em parecer ou auditoria.

Tema	LGPD	Onde a ISO/IEC 27701 trata
Bases legais e consentimento	arts. 7º e 11	Anexo A, condições de coleta e tratamento (A.7.2)
Transparência ao titular	arts. 9º e 18	Anexo A, obrigações perante os titulares (A.7.3)
Direitos do titular	art. 18	Anexo A, obrigações perante os titulares (A.7.3)
Minimização e privacidade desde a concepção	arts. 6º, III, e 46, § 2º	Anexo A, privacidade por concepção e por padrão (A.7.4)
Registro das operações, o ROPA	art. 37	Anexo A, registros do tratamento, dentro de A.7.2
Relatório de impacto, o RIPD	art. 38	Anexo A, avaliação de impacto, dentro de A.7.2
Compartilhamento e transferência internacional	arts. 33 a 36	Anexo A, compartilhamento e divulgação (A.7.5)
Papel do operador e instruções do controlador	arts. 39 e 42	Anexo B, instruções e obrigações do operador (B.8.2)
Subcontratação pelo operador	art. 39	Anexo B, divulgação e subcontratados (B.8.5)
Segurança do tratamento	art. 46	Cláusulas 5 e 6: o SGSI da 27001 estendido a dados pessoais
Comunicação de incidente	art. 48	Cláusula 6, gestão de incidentes envolvendo dados pessoais
Encarregado	art. 41	Cláusula 6, papéis e responsabilidades de privacidade

Como usar sem se queimar: a tabela aponta onde cada obrigação da lei encontra apoio na norma, na direção lei → norma. Serve para montar um programa único, evitar trabalho em dobro e responder ao auditor onde cada exigência mora. Não serve como parecer jurídico nem como prova de conformidade.

O erro mais comum: tratar a tabela como equivalência jurídica. A conformidade com a lei se demonstra pela lei, e a certificação comprova o sistema de gestão, não a litude de cada tratamento.